Note de sécurité — FasoLink

1. Menaces prises en compte et protections

Menace	Protections en place
Serveur saisi ou base volée	Chiffrement de bout en bout Olm/Megolm dans le navigateur : messages, fichiers, photos et vocaux arrivent chiffrés, et les clés privées restent sur les appareils. Mots de passe hachés en Argon2, secrets TOTP chiffrés (Fernet), seul le SHA-256 des jetons de session est stocké.
Contenu en clair envoyé au serveur	Le client refuse d'envoyer si le chiffrement n'est pas prêt. L'API vérifie la forme de chaque enveloppe (structure, base64, version du format Olm) et CouchDB refuse tout champ supplémentaire ou tout contenu hors format.
Intrus	Pas d'inscription libre : code d'activation à usage unique, valable 72 h, délivré par un administrateur. Mot de passe + TOTP obligatoires, code non réutilisable, 5 tentatives par tranche de 15 minutes. Un non-membre est refusé par le serveur sur une conversation.
Agent qui part, appareil perdu	Session, statut et appareil sont revérifiés à chaque requête. Le blocage coupe sessions, appareils et appartenances dans la même transaction ; l'interface de l'agent est éjectée en 3 s au plus et efface ses clés locales. L'envoi suivant d'un membre utilise une nouvelle clé de groupe. L'agent peut aussi déclencher le bouton d'urgence.
Administrateur compromis	Hiérarchie vérifiée côté serveur : l'admin n'agit que sur les agents, le superviseur sur agents et admins, personne sur lui-même. Dernier superviseur protégé. Journal d'audit en ajout seul, y compris pour le propriétaire de la base. Un administrateur ne peut pas lire les messages.
Hameçonnage	Le TOTP limite l'usage d'un mot de passe volé. Il ne protège pas contre un faux site qui relaie le code en temps réel : c'est une limite.
Interception réseau	HTTPS, en plus du chiffrement de bout en bout. Les bases n'écoutent que sur 127.0.0.1. Aucune ressource externe, politique CSP stricte. Certificat auto-signé en démonstration, certificat de l'État requis en production.
Substitution de clés par le serveur	Comparaison des empreintes dans la conversation ; si la clé d'un appareil vérifié change, l'envoi est bloqué.
Capture d'écran	Non bloquée, car un navigateur ne le permet pas. Dissuasion : filigrane nominatif, flou hors focus. Traçabilité : touche Impr. écran signalée au journal. Impression et copie des messages classifiés bloquées dans l'application.
Appareil volé éteint	Clés locales chiffrées avec une clé dérivée du mot de passe (PBKDF2-SHA256, 310 000 itérations).

26 tests automatisés (`tests/`) couvrent le second facteur, les rôles, le refus du clair et le blocage. Ils ne remplacent pas un audit de sécurité.

2. Métadonnées visibles par le serveur

Le serveur ne voit pas : le texte, les fichiers, photos et vocaux, les noms de fichiers, les clés privées, ni le contenu des accusés de lecture.

Le serveur voit :

- **Qui échange avec qui** : les membres de chaque conversation et les liaisons privées, y compris acceptées ou refusées. Le serveur connaît donc ce graphe d'échanges.
- **Quand et combien** : l'expéditeur, l'horodatage et la taille de chaque enveloppe, et son type (message ou clé).
- **La date d'expiration** : elle est en clair pour permettre la suppression. Un écart de 72 h ou de 24 h révèle donc qu'un message est classifié, et à quel niveau.
- **Les noms des groupes**, l'annuaire (nom, service, fonction), la liste des appareils et leurs clés publiques.
- **Les événements du journal d'audit** : connexions, refus, enrôlements, blocages, signalements de capture, avec auteur et date.

Mesures de réduction : aucun journal d'accès HTTP (ni IP, ni URL), PostgreSQL et CouchDB sans journal de requêtes, journaux Docker limités en taille, enveloppes expirées supprimées, flux temps réel limité aux identifiants de conversation, aucun contenu dans le journal d'audit. Conseil aux agents : donner aux groupes des noms neutres.

3. Limites connues

- **Bibliothèque :** libolm n'est plus maintenue depuis 2024 (successeur : vodozemac) et des faiblesses par canal auxiliaire y ont été signalées. Choix assumé pour ce prototype ; une migration serait nécessaire avant toute production.
- **Contrôle du clair :** il vérifie une forme, pas le chiffrement réel. Un client malveillant qui imite le format d'enveloppe peut le franchir ; le client officiel chiffre toujours.

- **Annuaire de clés :** le serveur distribue les clés publiques. Sans comparaison des empreintes par les agents, une substitution reste possible, et un administrateur malveillant peut enrôler un faux compte (action tracée).
- **Sécurité persistante :** le protocole est utilisé avec une clé de secours et non des clés à usage unique. La première prise de contact Olm a donc une garantie plus faible ; Megolm, par conception, ne renouvelle pas la clé à chaque message.
- **Appareil compromis :** un logiciel espion lit ce que l'agent voit. Les clés locales sont dans le `localStorage` ; pendant l'utilisation, la clé de déverrouillage est en mémoire de l'onglet.
- **Appareil hors ligne :** l'effacement local a lieu à la reconnexion. D'ici là, l'appareil garde ce qu'il a déjà reçu, sans recevoir de nouveaux messages du serveur.
- **Captures :** seule une application native pourrait les bloquer (FLAG_SECURE sous Android). Une photo de l'écran reste toujours possible.
- **Expiration :** l'enveloppe expirée est supprimée à la lecture suivante de la conversation, pas à l'heure exacte, et CouchDB garde une trace de la suppression jusqu'au compactage.
- **Nouveaux appareils :** ils reçoivent les clés quand un expéditeur revient en ligne. Si l'appareil d'origine a disparu, les anciens messages restent illisibles.
- **Exploitation :** la clé qui protège les secrets TOTP est dans `configuration/.env`, sur le serveur : une compromission complète du serveur expose ces secrets. La limitation des tentatives est gardée en mémoire (un seul processus serveur).
- **Mode démonstration :** `FASOLINK_DEMO=1` délivre des identifiants fictifs et ne doit jamais servir en production (`lancer.bat --sans-demo`).